

Recolección de información / Information disclosure

Recolección de información pasiva o Passive

Scanning

En esta sesión vamos a comenzar un nuevo módulo, en el módulo 11, donde vamos a tratar el tema de la información que es posible obtener a través de recursos que se encuentran expuestos en Internet.

Para ello vamos a ver el primer tipo de enumeraciones que se pueden realizar sobre un target, cómo realizarlas, a través de qué técnicas, qué ejemplos de herramientas y qué tipo de información podremos obtener en cada caso.

Passive scan:

- Dorks
- Leaks
- Leaks tools
- Search engines

Gather information thanks to data exposed.

Search for:

- ASN (Autonomous System Number)
- IPs
- Domains
- Subdomains

Comenzamos con el escaneo pasivo o passive scan, que recibe este nombre porque la obtención de la información es obtenida por la exposición que tiene el

propio target, ya sea una aplicación, una organización que tiene este target en Internet.

Para ello tendremos que fijarnos en aspectos como pueden ser la dirección IP o el dominio de la propia aplicación o del recurso, ya que a través de estos aspectos podremos obtener el ASN, de forma que dentro de una organización las direcciones IP y las aplicaciones suelen compartir el mismo ASN y esta es una primera forma de identificar si un recurso pertenece o está asociado a una organización.

Estos recursos están gestionados por una misma organización bajo un mismo paraguas y comparten este mismo ASN.

Además también los subdominios de las aplicaciones suelen ser en muchos casos anexos que tienen las aplicaciones, ya sean compartiendo o no la misma dirección IP, también nos aporta mucha información de diferentes secciones o temáticas que puede contener una aplicación web.

Dorks

Technique to perform advanced searches with operators

Takes advantage of the browser's search algorithms to locate specific text strings within search results

Applies to the different searchers:

- Google
- Bing
- Yahoo
- Yandex

La primera vía que vamos a obtener son los Dorks, que son operadores, palabras clave que nos permiten y nos ayudan a realizar búsquedas de una forma mucho más optimizada en los buscadores.

Los buscadores que conocemos, cómo Google, Bing, Yahoo, Yandex, etcétera.

Y de esta forma lo que obtenemos son resultados mucho más eficientes a la hora de querer encontrar información específica.

Con estas palabras clave, nuestros dorks, lo que se consigue es aprovechar los algoritmos de búsqueda que tiene cada tipo de buscador y eliminar resultados que no nos interesen.

También otro aspecto que tenemos que tener en cuenta es que cada buscador tiene operadores específicos de palabras genéricas de la misma forma que son compartidas entre estos buscadores.

Estas palabras clave, estos keywords, nos van a decir información específica según lo que queramos buscar y lo que queramos encontrar.

Keywords:

- Site: results from a specific website
- Inurl: search for pages where all the words are in the url
- Intext: search for the word within the body of the text on the page
- Cache: previous versions of the website
- Link: will list webpages that have links to the specified webpage
- Ext: Filters by file extension
- Filetype: Filters by type of documents

En el caso de Site vamos a encontrar resultados de una web específica.

Inurl nos va a indicar resultados que pueden estar en diferentes aplicaciones, pero que las palabras clave que ya hemos puesto en ese Inurl van a encontrarse esos resultados en la URL de las aplicaciones que nos muestra.

De la misma forma Intext lo que hace es mostrar los resultados cuyas palabras clave se encuentran en el cuerpo de las aplicaciones que nos muestra como resultados.

Cache lo que hace es mostrarnos versiones previas, versiones antiguas de una aplicación.

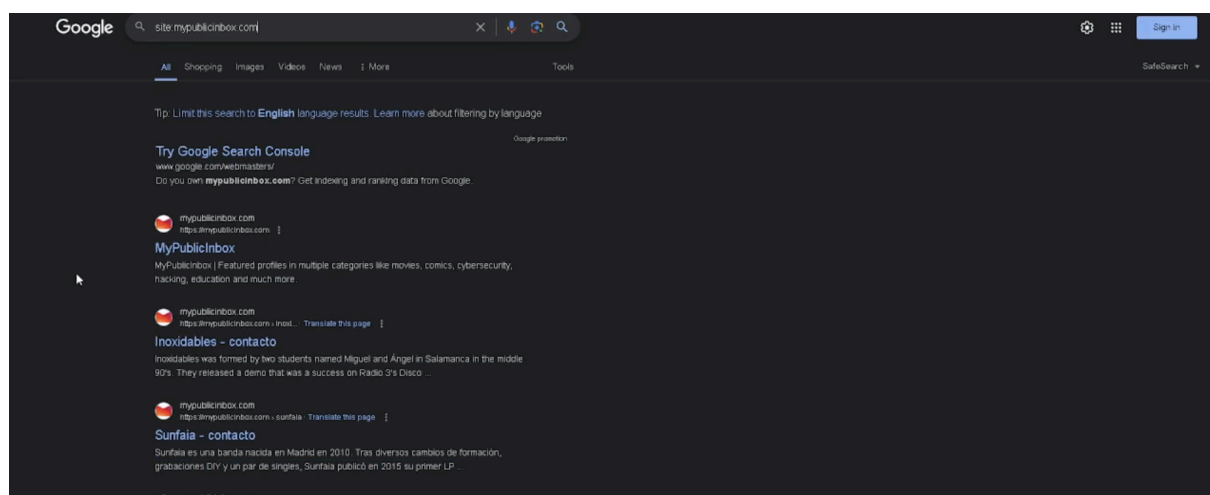
El operador Link lo que nos muestra son aplicaciones que tienen enlaces de una aplicación web específica.

Y los operadores Ext y Filetype lo que nos muestran son diferentes formatos, diferentes extensiones de un fichero que puedan estar contenidos en una aplicación web.

De la misma forma tenemos que tener en cuenta que estos operadores pueden ser combinados y se puede potenciar muchísimo la búsqueda que queramos realizar.

Para ello vamos a ver algunos ejemplos donde el primer caso que vamos a hacer y que vamos a buscar es con Site y MyPublicInbox, por ejemplo, los resultados que nos va a mostrar son todos dentro de la aplicación de MyPublicInbox.

site:mypublicinbox.com



Nos puede mostrar diferentes campos, diferentes secciones de la aplicación, pero en cualquiera de los casos los resultados van a ser de la aplicación de MyPublicInbox.

De la misma forma, si queremos filtrar o modificar esta búsqueda podemos poner operador Filetype y poner por ejemplo la extensión PDF, que en este caso no nos va a mostrar ningún resultado.

site:mypublicinbox.com filetype:pdf

Podríamos cambiarla a xls, a txt.

En este caso podemos encontrarnos la tesitura de que no haya ningún resultado optimizado para este dork, pero podemos cambiarlo por ejemplo al caso de inurl.

`inurl:mypublicinbox.com`

De esta forma nos va a mostrar muchos resultados que en este caso tengan MyPublicInbox dentro de la URL los resultados.

Leaks

Credentials and sensitive data exposed through data breaches

Used to get entry points to the authenticated side of applications or infrastructures

Might contain:

- Emails
- Usernames
- User IDs
- Personal IDs
- Passwords
- Credit cards
- etc

Otro aspecto que tenemos que tener muy en cuenta son los leaks.

Los leaks son al fin y al cabo credenciales o datos sensibles que se encuentran expuestos en Internet debido a fallos de seguridad de empresas u organizaciones.

Una empresa, una plataforma ha tenido un fallo de seguridad, un ciberdelincuente ha expuesto la información de la base de datos en Internet, esa base de datos se ha hecho pública y se han obtenido credenciales o información personal que se encuentra más contenida en esas bases de datos.

Esta información nos puede servir para entrar tanto en aplicaciones que estemos auditando o que vayamos a auditar, como nos puede servir en vectores de entrada o puntos de entrada a la hora de auditar la infraestructura de una organización.

Si nos autenticamos como un usuario que ha podido sufrir, que pueda formar parte de un leak y que haya reutilizado o no haya cambiado las credenciales que se encontraban expuestas, para nosotros como auditores es un vector de entrada para la infraestructura de ese target de esa organización.

Entonces es información que como auditores debemos tener muy en cuenta para analizar y comprobar que esa información haya sido actualizada.

También otro aspecto que tenemos que tener en cuenta es que dentro de esta información en los leaks se pueden encontrar datos como emails, nombres de usuario, identificadores de usuarios que se puedan encontrar en las plataformas, ya sean cadenas de caracteres o ya sean identificadores numéricos.

De la misma forma se puede aplicar al plano personal fuera del mundo digital, que se pueden encontrar ID de personas físicas y de la misma forma se pueden encontrar las contraseñas que ese usuario estuviera usando en esa plataforma determinada.

De la misma forma, si la plataforma que fue expuesta o la aplicación o el sistema o la organización que sufría la base de datos tenía partes o funcionalidades que requerían pagos y almacena las tarjetas de crédito, también se han expuesto en algunos casos las propias tarjetas de crédito en los leaks y es otra información sensible que se ha expuesto.

Es importante recordar que, si bien esta información puede estar disponible en Internet, su almacenamiento personal es ilegal. Por lo tanto, para verificar esta información, no es recomendable guardarla a nivel local. En su lugar, existen plataformas y herramientas diseñadas para confirmar si una persona o una organización ha sufrido una brecha de datos o si hay filtraciones que afectan a usuarios o empleados de esa organización.

Para ello, para comprobarlo tenemos como algunos de los muchos ejemplos de herramientas para verificarlo, pues haveibeenpwned, dehashed, leakcheck, leakix,

leak-lookup, son las herramientas más conocidas para confirmar estas brechas de datos o si usuarios se pueden encontrar con credenciales expuestas en Internet.

Vamos mirar algunos ejemplos, podemos, en haveibeenpwned.com, ver el clásico `test@test.com` que es un usuario de pruebas que se usa muchas veces. En este caso nos muestra que tiene credenciales expuestas en Internet, nos indica en qué bases de datos, de qué organizaciones se han comprometido esas credenciales, aunque también hay que decir que no se muestran las credenciales que se han expuesto, que se han filtrado, es una herramienta espectacular y es muy usada.

De la misma forma dehashed es una herramienta que es principalmente de pago, pero sus resultados son espectaculares y muy fiables.

Y de la misma forma tenemos leakcheck que podemos hacer uso tanto de emails como de nombres de usuario en aplicaciones y plataformas como Leakix. Y Leak-lookup.

En cualquier caso estas herramientas nos van a mostrar información de usuarios de credenciales que se han encontrado expuestas en Internet.

Search engines

Tenemos Shodan, Censys, Fofa, crt.sh, SecurityTrails, riskiq, zoomeye.

De otra forma tenemos también formas de encontrar información de recursos que se encuentran expuestos en Internet.

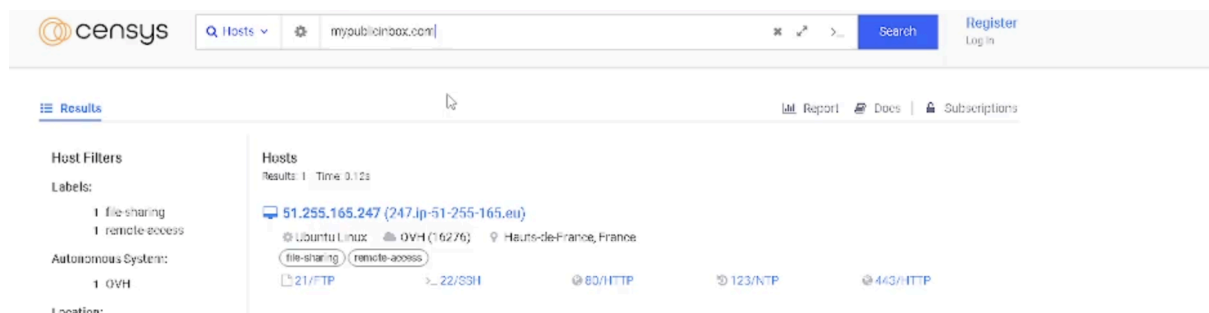
Vamos a ver estos tipos de buscadores porque son herramientas que nos ayudan a identificar recursos que se encuentran expuestos en Internet, qué servicios pueden tener expuesto, toda esta información sin establecer conexión con los recursos que queremos identificar.

Vamos a ver en el primer caso **Shodan**, que es una aplicación que es considerada el Google de los dispositivos conectados a Internet. En este primer caso vamos a

buscar no una organización, no un target como tal, sino un tipo de servidor, ya que no solamente podemos buscar targets, sino tecnologías que son usadas por dispositivos que se encuentran conectados a Internet, nos va a buscar de los dispositivos que tiene indexados en este buscador los que coinciden con las palabras clave que vamos a indicar y de esta forma nos va a mostrar información relacionada con sus resultados.

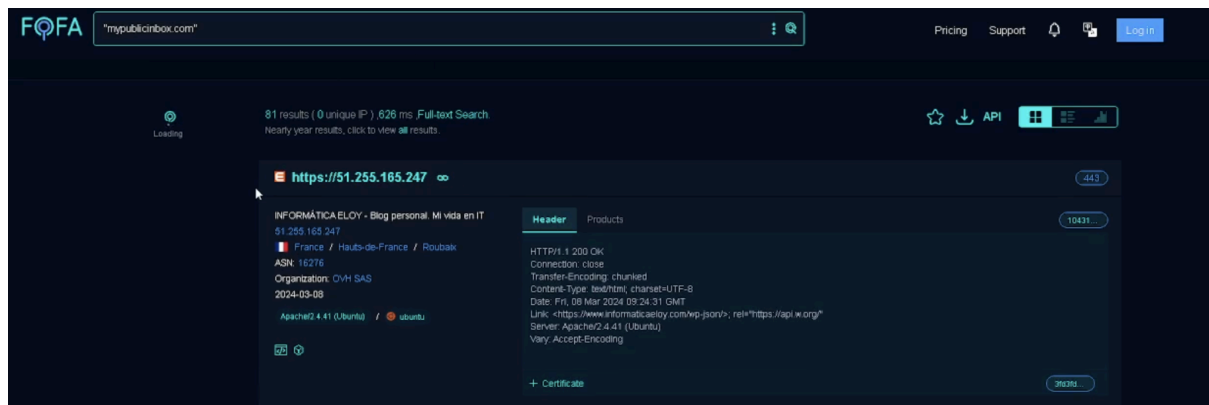
De la misma forma tenemos **Censys** que en este caso podemos buscar tanto host y dispositivos como certificados que puedan encontrarse firmados por una organización a dos días a por una organización.

En este caso vamos a buscar Mypublicinbox.com y nos indica la dirección IP que se encuentra asociada a este dominio, los servicios que se encuentran expuestos y habilitados dentro de esta dirección IP, información como el tipo de servidor, la ubicación del servidor y esto aplicado a cualquier target, a cualquier dominio que podamos interesarnos por buscar.



Fofa es considerada como el Shodan chino porque es una aplicación de origen chino, pero nos muestra de la misma forma dispositivos que se encuentran expuestos en Internet.

Vamos a hacer una búsqueda similar y en este caso como podemos ver los resultados son diferentes.



De esta forma nos muestra información que pueda estar asociada de una forma u otra a Mypublicinbox y nos va a dar información asociada a ella.

También es necesario indicar que en cualquiera de los casos de las herramientas que estamos comentando, podemos hacernos una cuenta gratuita que nos va a mostrar mucha más información que si somos usuarios que no estamos autenticados en la plataforma.

De la misma forma podemos buscar información sobre los certificados a través de la aplicación **crt.sh**.

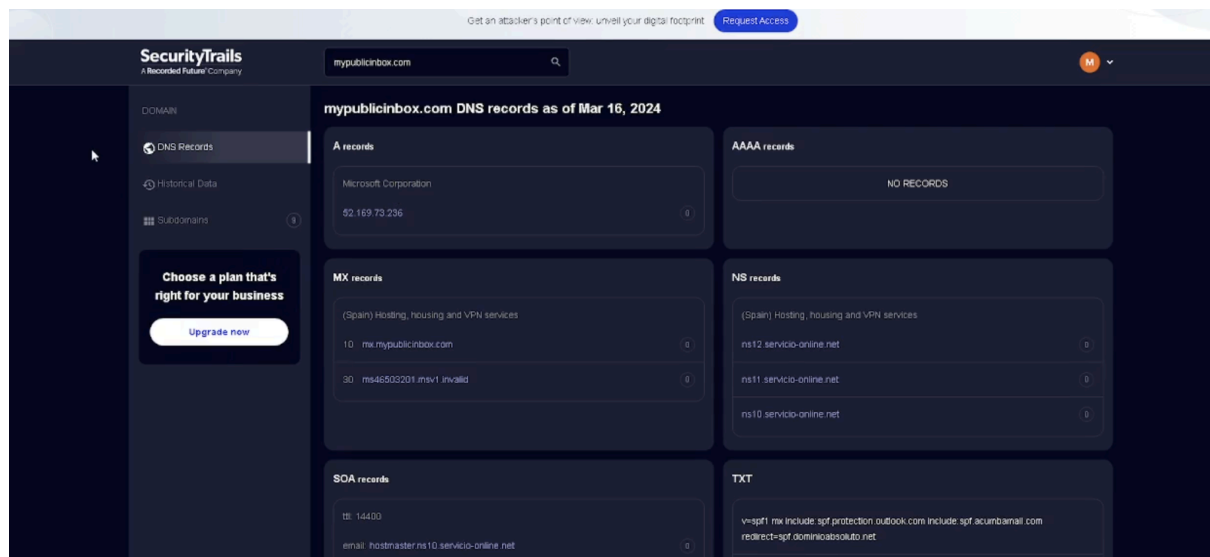
En este caso no sólo nos muestra los certificados que se encuentran asociados a este dominio, sino también puede darnos resultados que se encuentren asociados a subdominios, lo que nos facilita bastante a la hora de encontrar subdominios que se puedan encontrar que estén asociados a esta aplicación.

Es una herramienta que nos va a permitir realizar búsquedas sobre un target, nos va a indicar información de los certificados que están formados, firmados sobre una misma organización y que nos va a indicar dominios, subdominios, información sobre estos certificados y podremos ampliar nuestra base de datos de recursos que puedan pertenecer a un mismo target.

Ahora vemos **SecurityTrails**, podemos buscar a través de un dominio, una dirección IP, palabras clave o incluso un hostname.

Para ello vamos a repetir Mypublicinbox y nos realiza búsquedas en cuanto a información que se puede encontrar en el servidor a nivel de nameservers, de la información por defecto que puede encontrarse asociada la dirección IP, incluso

tenemos una sección de subdominios que se encuentren asociados y activos a la aplicación o al recurso que le indicamos en el buscador.



De la misma forma la aplicación y la plataforma de **riskiq**, nos va a dar información similar, pero estas aplicaciones al usar algoritmos diferentes vamos a tener en cuenta que los resultados van a ser diferentes y a través de estas plataformas vamos a poder contrastar información que tendremos entre unos resultados y otros y de esta forma podremos realizar una base de datos entre los resultados que vayamos obteniendo de las diferentes aplicaciones.

Entonces vamos a poner mypublicinbox.com y de esta forma nos va indicando diferentes secciones, diferente información. En cada caso nos va a indicar información diferente de todo lo que queremos ir obteniendo. Aquí en este caso nos indica diferentes resoluciones, diferentes certificados, y vamos a poder obtener diferentes resultados a través de estas herramientas.

Tal y como hemos visto también replicamos esta información sobre los certificados que podremos encontrar y SecurityTrails y riskiq nos van a mostrar no solamente información a nivel de direcciones IP, a nivel de certificados, sino también nos complementa con posibles subdominios que estén asociados, que estén habilitados bajo los dominios que hemos indicado en los buscadores (internal resources).

Como conclusiones de esta sesión podemos indicar que los activos, los recursos que se encuentran expuestos en Internet van a ser identificados y analizados con la configuración que puedan tener y recursos tales como los subdominios de la misma

forma, hemos visto que hay diferentes formas de conseguir datos de un activo, de un recurso, de una aplicación, de una dirección IP, sin establecer contacto directo con este activo, con este target, que es de lo que se trata, como hemos dicho al comienzo del de la sesión, el escaneo pasivo.

Aunque todas estas herramientas se utilizan para la fase de enumeración y detección de vulnerabilidades, cada una tiene un enfoque especializado:

Shodan

Shodan es conocido como el "motor de búsqueda para hackers" porque se centra en escanear dispositivos y servicios conectados a Internet. A diferencia de un buscador tradicional, Shodan busca elementos como servidores, routers, cámaras web y sistemas de control industrial. Es ideal para encontrar dispositivos que exponen puertos específicos o que ejecutan versiones de *software* con vulnerabilidades conocidas.

Censys

Censys también escanea activamente Internet, pero su especialidad es el análisis de la configuración de los servicios. Es una herramienta muy poderosa para investigar certificados SSL, protocolos de red e identificar la tecnología subyacente de un servidor, lo que puede dar pistas sobre configuraciones incorrectas o vulnerabilidades.

Fofa

Fofa es otro motor de búsqueda de ciberseguridad similar a Shodan y Censys. Su principal ventaja es la gran cantidad de parámetros de filtrado que ofrece, lo que permite a los atacantes encontrar hosts, dominios y servicios de manera muy específica y eficiente.

Crt.sh

Crt.sh es una base de datos de certificados SSL/TLS que permite a los atacantes encontrar todos los dominios y subdominios asociados a un dominio principal. Esta información es muy valiosa en la fase de reconocimiento para expandir el alcance de un ataque y descubrir activos que podrían ser más fáciles de comprometer.

SecurityTrails

Esta plataforma se enfoca en el historial de datos de dominios y DNS. Los atacantes pueden usarla para analizar cambios en las direcciones IP, subdominios antiguos y tecnologías utilizadas por una organización a lo largo del tiempo, lo que puede revelar infraestructuras obsoletas que podrían ser vulnerables.

RiskIQ

RiskIQ, que ahora forma parte de Microsoft, es una herramienta de inteligencia de amenazas que mapea la superficie de ataque digital completa de una organización. Ayuda a identificar activos web, dominios y certificados, incluso aquellos que la propia empresa podría desconocer, lo que brinda a los atacantes una visión holística para encontrar puntos de entrada.

ZoomEye

ZoomEye es un motor de búsqueda que escanea Internet y utiliza una tecnología de "huellas dactilares" para identificar dispositivos y componentes de *software* específicos. Es muy útil en la fase de reconocimiento para encontrar rápidamente sistemas que utilizan una tecnología concreta o que tienen vulnerabilidades conocidas.

En resumen, mientras que algunos se enfocan en el escaneo de servicios activos (Shodan, Censys, Fofa), otros se especializan en la recopilación de datos de dominios y certificados (Crt.sh, SecurityTrails). Herramientas como RiskIQ y ZoomEye ofrecen una perspectiva más amplia al mapear la superficie de ataque completa de una organización.

Ejemplo de recolección de información:

metasploitable2

En esta sesión vamos a continuar con la información que es posible obtener a través de recursos que tenemos expuestos o que podemos identificar expuestos en Internet.

Y para ello, previamente necesitamos conocer una herramienta que nos va a ayudar a realizar pruebas en entornos controlados.

Esta herramienta se trata de Metasploitable2, es una máquina virtual que ya está configurada con servicios vulnerables, con puertos cuya configuración en esos servicios asociados están incorrectamente configurados de forma que tienen un conjunto de vulnerabilidades preparadas para ser explotadas y que precisamente con esta máquina virtual aprendamos a explotar vulnerabilidades cuyos servicios no están bien configurados.

Entonces es una forma muy buena de aprender a aplicar los conocimientos que podamos tener, que podamos aprender en la propia máquina local, en nuestro propio equipo, ya que tenemos un enlace de descarga directo, la podemos descargar en nuestro equipo, podemos importar la máquina virtual, está en un fichero comprimido, pero lo extraemos, descomprimimos y lo importamos en nuestro software de virtualización.

<https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>

Entonces, una vez lo hayamos extraído, lo hayamos importado, arrancaremos la máquina virtual e introduciremos las credenciales msfadmin / msfadmin.

Para ello vamos a realizar una prueba.

Aquí ya tenemos la máquina virtual descargada, importada y arrancada, y lo que hemos hecho es dejar que arranque todos los servicios que tiene para autenticarnos, sencillamente introduciremos las credenciales por defecto.

Y otro factor que debemos tener en cuenta es que esta es una máquina víctima, llamémosla, a la que vamos a realizar peticiones, a la que vamos a realizar ataques.

Entonces, para tener visibilidad con otras máquinas virtuales que vayamos a tener habilitadas y levantadas, necesitamos que esta máquina virtual esté en modo NAT, la configuración de red de la máquina virtual.

Y para ello vamos a ver también la dirección IP local que nos asocia.

Y una vez tenemos confirmado y configurado este aspecto, ya podríamos empezar a realizar pruebas sobre los servicios que tiene habilitados y configurados esta máquina virtual y este entorno.

Como conclusiones de esta sesión podemos decir que este recurso es una máquina virtual, es una herramienta que es muy fácil de configurar en nuestro equipo, que está disponible, es totalmente gratuita y es un entorno seguro donde podemos realizar pruebas, donde podemos aprender todos los conceptos, todas las técnicas y todos los ataques que podamos aprender de forma segura, de forma que no vamos a atacar ningún recurso que se encuentra realmente en producción expuesto en Internet, ya que de esta forma podríamos estar cometiendo un delito sin saberlo.

Recolección de información activa o Active

Scanning

En esta sesión vamos a continuar con la información que podemos obtener a través de los recursos que se encuentran expuestos en Internet.

En este caso veremos cómo obtener información directamente desde un target, no a través de terceros, sino directamente realizando peticiones y qué tipo de información podremos conseguir.

- Active scan
 - Obtain information performing requests to the target directly.
 - It is needed previous authorization from the owner/client.
 - Known as fingerprinting.
- Search for
 - Available services/protocols.
 - Operative systems and technologies.
 - Default configuration.
 - Internal resources (directories/files).

En el caso del escaneo activo, las peticiones y las búsquedas se realizan directamente sobre el target del que queremos obtener la información.

Además, también para enumerar los recursos y obtener información en estos escaneos activos es imprescindible tener la aprobación previa del cliente.

En este punto vamos a asumir que ya se ha establecido una planificación de la auditoría que podamos realizar sobre el target y dentro de ella conoceremos el alcance de los activos de los targets a auditar.

Por lo tanto, podremos realizar directamente peticiones sobre estos activos, sobre estas aplicaciones.

Además, también el escaneo o la enumeración activa, también es conocida como Fingerprinting.

En esta numeración activa, en este escaneo activo, lo que vamos a buscar son los recursos, los servicios, los puertos que se encuentran habilitados y configurados en el target.

Además, vamos a buscar también por posibles tecnologías que use esa aplicación por los sistemas operativos que puedan haber detrás en los servidores, por configuraciones, recursos por defecto y por ficheros y directorios.

Pero, ¿Cómo vamos a conseguir esto?

Gracias a lo que conocemos y a lo que se llama como Spidering y Crawling.

Spidering y Crawling

En primer lugar, para tener un mayor conocimiento de estos recursos que tiene expuestos una aplicación, vamos a tener que analizar el contenido de la aplicación.

El **Spidering** se trata de hacer la extracción de los enlaces de los links que puedan estar contenidos en el código fuente de una aplicación, de forma que se identifican tanto las tecnologías usadas por esta aplicación como las llamadas internas que se hagan entre los propios recursos que se encuentran en la aplicación, entre las diferentes funcionalidades o secciones que hay en la aplicación.

Spidering: Extract links from websites using automated scripts to perform.

Para ello también las herramientas o los scripts que se usan se llaman spiders.

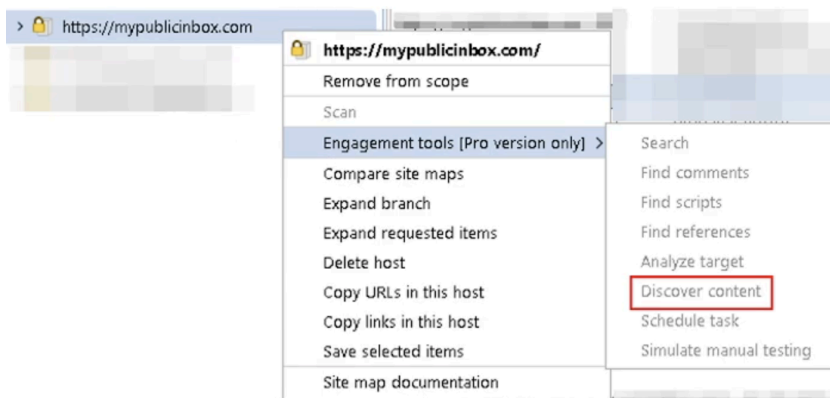
Por otro lado se encuentra el **Crawling**, que consiste en la búsqueda de los recursos que puedan estar configurados en la propia aplicación y estos recursos pueden identificarse en forma tanto de directorios como de ficheros, por lo que la obtención de estas rutas permite dar un mejor conocimiento de la arquitectura de la aplicación.

Dictionaries: Rockyou, SecLists, Dirb, DirBuster, PayloadsAllTheThings, etc.

Crawling: Obtain files and folders from a website through brute force attacks using dictionaries. Also known as fuzzing.

Además, también otro factor del Crawling es que para la enumeración y la obtención de estos recursos es necesario el uso de diccionarios, porque la técnica que hay detrás de esta prueba, de esta obtención de recursos, consiste al fin y al cabo de un ataque de fuerza bruta solicitando acceso a cada uno de los elementos que se encuentran en el diccionario que usemos, de forma que si la respuesta del servidor es satisfactoria podemos deducir que el recurso que la ruta que hemos solicitado existe en la aplicación.

Para ello hay herramientas como pueden ser Burpsuite que en la versión Pro tiene diferentes secciones que tiene configuradas secciones, funcionalidades que nos van a permitir buscar recursos en la aplicación.



Estas funcionalidades pues podemos verlas como Find comments, Find scripts, Find references, y la más interesante es Discover content, con las que también es posible buscar diferentes tipos de recursos según se desee, como decimos en el caso de la funcionalidad de discover content.

Además se realiza la búsqueda por fuerza bruta que comentamos de posibles directorios y ficheros que puedan existir en la aplicación que nos interese.

Algunos de estos diccionarios para realizar este tipo de pruebas pueden ser Rockyou, Seclists, Dirb, Dirbuster, kits de payloads como puede ser Payloadsallthethings, que se encuentran disponibles en Internet y son accesibles y gratuitos.

Por otro lado, para usar estos diccionarios podemos apoyarnos en una gran variedad de herramientas como las que tenemos a continuación: Dirb, DirBuster, Dirsearch, Gobuster, Wfuzz, ffuf, etc.

En este caso vamos a realizar un ejemplo usando la herramienta Metasploitable como máquina víctima de nuestras pruebas y Kali Linux como la máquina atacante desde la que vamos a realizar las peticiones.

Para ello podemos ver que tenemos la máquina Metasploitable habilitada y por otra parte tenemos Kali Linux desde donde hemos realizado una petición que la he dejado corriendo mientras realizaba la explicación porque estas herramientas suelen tardar bastante tiempo en buscar los recursos.

```
root@kali:~# dirsearch -u http://192.168.186.132/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11660
Output File: /root/reports/http_192.168.186.132/___24-03-17_08-05-34.txt
Target: http://192.168.186.132/

[00:05:34] Starting:
[00:05:41] 403 - 3020 - /.htaccess.orig
[00:05:41] 403 - 3020 - /.htaccess.bak1
[00:05:42] 403 - 3040 - /.htaccess.sample
[00:05:41] 403 - 3030 - /.htaccess_extra
[00:05:41] 403 - 2990 - /.ht_wsr.txt
[00:05:41] 403 - 3000 - /.htaccessOLD
[00:05:41] 403 - 3000 - /.htaccessbak
[00:05:41] 403 - 3020 - /.htaccess.orig
[00:05:41] 403 - 3010 - /.htaccessOLD2
[00:05:41] 403 - 3020 - /.htaccess.save
[00:05:41] 403 - 3000 - /.htaccess_sc
[00:05:41] 403 - 2920 - /.htm
[00:05:41] 403 - 2900 - /.htpasswd
[00:05:41] 403 - 2900 - /.htpasswd
[00:05:41] 403 - 2900 - /.htpasswd
[00:05:41] 403 - 2920 - /.html
[00:05:41] 403 - 3020 - /.htpasswd_test
[00:06:38] 403 - 2900 - /cgi-bin/
[00:06:45] 200 - 111KB - /doc/
[00:06:46] 202 - 0B - /dwa/ → login.php
[00:07:22] 200 - 24KB - /multilidae/
[00:07:32] 200 - 49KB - /phpinfo
[00:07:32] 200 - 49KB - /phpinfo.php
[00:07:32] 201 - 320B - /phpMyAdmin/ → http://192.168.186.132/phpMyAdmin/
[00:07:36] 200 - 4KB - /phpMyAdmin/
[00:07:36] 200 - 4KB - /phpMyAdmin/index.php
[00:07:51] 403 - 3020 - /server-status/
[00:07:51] 403 - 3010 - /server-status
[00:08:07] 301 - 322B - /test → http://192.168.186.132/test/
[00:08:08] 200 - 886B - /test/
[00:08:09] 301 - 326B - /tikiwiki → http://192.168.186.132/tikiwiki/

Task Completed
root@kali:~#
```

Entonces lo que he realizado es con **ifconfig** conocer la dirección IP de nuestra máquina víctima (Metasploitable) o nuestro dominio en el caso de que pueda ser una aplicación expuesta en Internet y directamente con el parámetro **-u** a **dirsearch** le decimos que es el target del que queremos realizar el descubrimiento de recursos.

dirsearch -u http://192.168.106.132

- **dirsearch**: Es la herramienta que se está ejecutando.

- **-u:** Indica la URL del objetivo, en este caso, la dirección IP `http://192.168.106.132`. El programa intentará encontrar archivos y directorios en este servidor.

El **output** de la terminal muestra los resultados del escaneo, lo que proporciona información valiosa para un atacante:

- **Líneas de inicio:** Se muestran los detalles de la configuración del ataque: las extensiones de archivo que se están buscando (`php`, `php4`, `php3`, `jsp`, `html`, `js`), el método **HTTP** utilizado (`GET`), y el tamaño de la lista de palabras (`11640`), entre otros detalles.
- **Resultados del escaneo:** Las líneas subsiguientes detallan los intentos del `dirsearch` y las respuestas del servidor. Cada línea incluye:
 - **Código de estado HTTP:** Como `200` (OK), `301` (Movido), `403` (Prohibido) o `404` (No encontrado). Un código `200` o `301` indica que se ha encontrado un archivo o directorio válido.
 - **Tamaño:** El tamaño del recurso encontrado.
 - **Ruta del archivo/directorio:** La ruta que el escáner intentó y tuvo éxito en encontrar, como `/admin.php`, `/robots.txt` o `/phpMyAdmin`.
- **Archivos y directorios importantes:** El escaneo reveló la existencia de varios recursos que un atacante consideraría valiosos:
 - `robots.txt`: Este archivo a menudo contiene una lista de directorios que el administrador del sitio no quiere que los motores de búsqueda indexen, lo que podría revelar ubicaciones de interés.
 - `phpMyAdmin`: Un panel de administración web para bases de datos MySQL, que podría tener vulnerabilidades o credenciales por defecto.
 - `/admin/`: Un directorio de administración, que es un objetivo principal para la escalada de privilegios.
 - `_my_sql_dumper_`: El nombre de un *script* que, por su nombre, parece ser una herramienta de respaldo de la base de datos, lo que podría contener información sensible.

En resumen, la salida de **dirsearch** es un mapa de la aplicación que el atacante puede usar para continuar con su ataque, explotando los recursos y directorios encontrados.

```
Target: http://192.168.186.132/

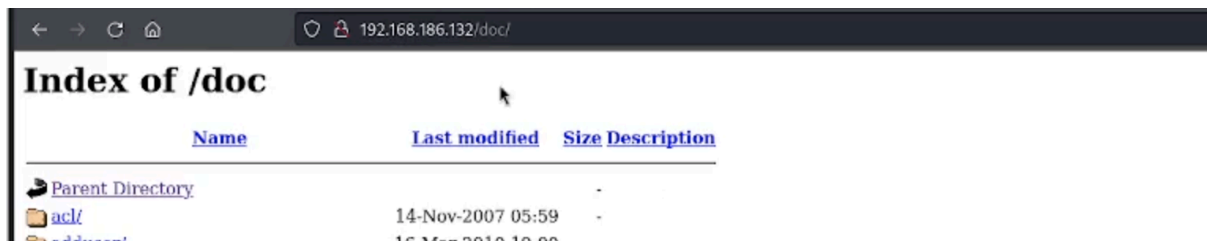
[08:05:34] Starting:
[08:05:41] 403 - 302B - /.htaccess.orig
[08:05:41] 403 - 302B - /.htaccess.bak1
[08:05:41] 403 - 304B - /.htaccess.sample
[08:05:41] 403 - 303B - /.htaccess_extra
[08:05:41] 403 - 299B - /.ht_wsr.txt
[08:05:41] 403 - 300B - /.htaccessOLD
[08:05:41] 403 - 300B - /.htaccess8AK
[08:05:41] 403 - 302B - /.htaccess_orig
[08:05:41] 403 - 301B - /.htaccessOLD2
[08:05:41] 403 - 302B - /.htaccess.save
[08:05:41] 403 - 300B - /.htaccess_sc
[08:05:41] 403 - 292B - /.htm
[08:05:41] 403 - 298B - /.htpasswd
[08:05:41] 403 - 299B - /.httr-oauth
[08:05:41] 403 - 293B - /.html
[08:05:41] 403 - 302B - /.htpasswd_test
[08:06:30] 403 - 296B - /cgi-bin/
[08:06:45] 200 - 111KB - /doc/
[08:06:46] 302 - 0B - /dvwa/ → login.php
[08:07:22] 200 - 24KB - /mutillidae/
[08:07:32] 200 - 49KB - /phpinfo
[08:07:32] 200 - 49KB - /phpinfo.php
[08:07:33] 301 - 328B - /phpMyAdmin → http://192.168.186.132/phpMyAdmin/
[08:07:36] 200 - 4KB - /phpMyAdmin/
[08:07:36] 200 - 4KB - /phpMyAdmin/index.php
[08:07:51] 403 - 302B - /server-status/
[08:07:51] 403 - 301B - /server-status
[08:08:07] 301 - 322B - /test → http://192.168.186.132/test/
[08:08:08] 200 - 886B - /test/
[08:08:09] 301 - 326B - /tikiwiki → http://192.168.186.132/tikiwiki/

Task Completed
```

Para ello tiene ya un diccionario preconfigurado que si no le indicamos otro diccionario con el parámetro **-w** realiza una búsqueda de diferentes ficheros y directorios que pueden estar contenidos, en este caso ya no sólo por el color del propio output de la herramienta, sino porque nos muestra el código de la respuesta del servidor ante estas peticiones. Con el 403 nos indica que son recursos que tenemos como forbidden que no tenemos accesibles por el tipo de usuario que podamos desde el que podamos estar realizando las peticiones.

En el caso de la petición 200 nos indica que ese recurso esta ruta está accesible (**/doc/**), de forma que si escribimos en el navegador la ip de la maquina victima y la ruta **/doc/**, nos va a indicar que efectivamente está el recurso accesible y vamos a tener un mayor conocimiento de la infraestructura y de todos los recursos que pueda tener expuestos en su configuración.

192.168.186.132/doc/



Ésto es posible porque ya tenemos la máquina metasploitable en el navegador, porque al ser una aplicación web sabemos que tiene el puerto 80 ya configurado.

Resumen: hemos hecho una petición con la herramienta dirsearch y hemos obtenido información directamente de la víctima.

Por lo tanto, como conclusiones de esta sección podemos decir que para diferenciarnos del escaneo y de la enumeración pasiva, la enumeración activa lo que hace es realizar peticiones de forma directa al target del que queremos obtener la información y que los recursos que se encuentran configurados en nuestro target pueden ser enumerados e identificados gracias a herramientas como Spiders o Crawlers que también nos ayudan a encontrar recursos internos que pueda tener configurados la aplicación, teniendo la ayuda también de los diccionarios correspondientes que queramos usar según el tipo de recursos que queramos obtener en esta enumeración.

Propuesta de ejercicio:

Esta sesión se trata de un vídeo corto donde vamos a proponer un ejercicio para practicar todas las técnicas de enumeración de obtención de información que hemos comentado en este módulo de obtención de información y exposición de información.

Para ello, en este ejercicio lo que proponemos es buscar información que se puede encontrar expuesta o compartida en Internet a través de dorks de la aplicación de mypublicInbox.com.

Podemos realizar tanto buscadores con Google, con Bing, Yahoo, con nuestro buscador favorito.

Por otro lado, podríamos realizar un ejercicio de conocimiento del estado de nuestras credenciales, de nuestra información personal y conocer en qué estado están nuestras credenciales, si nuestras contraseñas, nuestros emails que están asociados a brechas de datos.

Por ello, entre las herramientas que hemos visto para comprobarlo, os invito a que probéis vuestras cuentas personales de email para ver si están asociadas a brechas de datos o si las credenciales que usáis no son seguras.

Como último punto, se recomienda para este módulo que hagáis un análisis de la aplicación de DVWA y busquéis los recursos, los directorios y los ficheros que se puedan encontrar expuestos dentro de esta aplicación.

Resolución de ejercicio:

En esta sesión vamos a tratar de resolver el ejercicio propuesto para el módulo de la exposición de información y la obtención de información que hay expuesta en Internet de targets que queramos analizar y enumerar.

Vamos a ver las herramientas que hemos ido viendo y comentando.

Para ello vamos a recordar los ejercicios que habíamos propuesto.

Buscar información con Dorks:

En primer lugar teníamos buscar información expuesta de la aplicación de MyPublicInbox o 0xWord a través de Dorks, vamos a ir punto por punto resolviéndola.

Por lo que para este primer caso vamos a hacer uso de Kali Linux y como decíamos, en primer lugar vamos a buscar mypublicinbox.com con el operador site.

```
site:mypublicinbox.com
```

Aquí nos muestra todos los resultados, todas las URLs de la página web de MyPublicInbox.

De la misma forma podemos hacer de 0xWord. Por poner otro ejemplo también y ver otro tipo de resultados y vemos que todos los resultados, todas las secciones de la web que salen en los resultados con esta petición, pues pertenecen a la aplicación de 0xWord.

```
site:0xword.com
```

Por otra parte podemos continuar con este mismo ejemplo, por ejemplo podemos usar el operador inurl y aquí nos va a mostrar no solamente resultados de 0xWord, sino otras aplicaciones que mencionan a 0xWord.

```
inurl:0xword.com
```

De la misma forma podríamos comentar por ejemplo versiones anteriores que haya tenido esta aplicación con cache.

```
cache:0xword.com
```

Nos muestra una versión completa anterior que se encuentra cacheada de la aplicación de 0xWord y podemos incluir dentro de esta búsqueda el operador Filetype, digamos PDF por ejemplo, y aquí nos aparece un PDF que se encuentra en un recurso de 0xWord.

```
inurl:0xword.com filetype:pdf
```

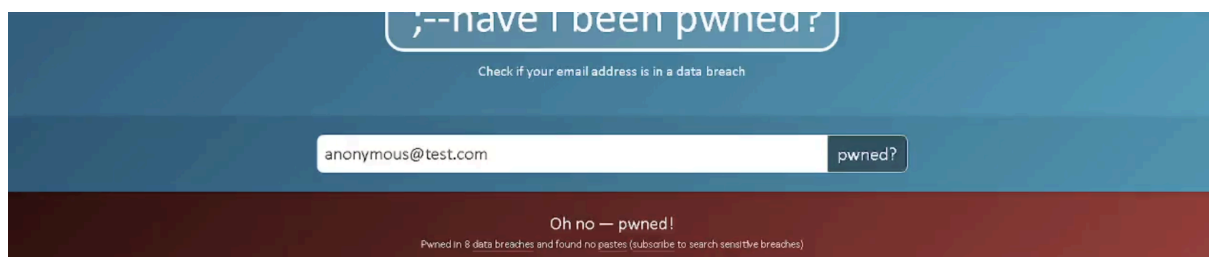
De la misma forma podremos realizar este tipo de búsquedas aplicado a cualquier otra aplicación que queramos analizar.

Comprobar si emails nuestros tienen leaks o se encuentra en filtrados de datos:

Volvemos al segundo reto, al segundo ejercicio que proponemos en este ejercicio y es comprobar si cuentas que haya personales de cada uno y de nosotros contienen leaks o se encuentran infiltraciones de bases de datos que hay expuestas en Internet.

Para ello, en este caso, para la resolución de este ejercicio se va a usar un usuario de pruebas ficticio.

Vamos a hacer uso en primer lugar de la aplicación haveibeenpwned.com y el usuario que vamos a tratar es anonymous@test.com.



En este caso por ejemplo nos dice que está en 8 brechas de bases de datos.

Nos va a decir cada una de las bases de datos en las que se encuentra esa brecha, pero no nos va a decir las credenciales que están asociadas a ese mail en cada una de esas bases de datos.

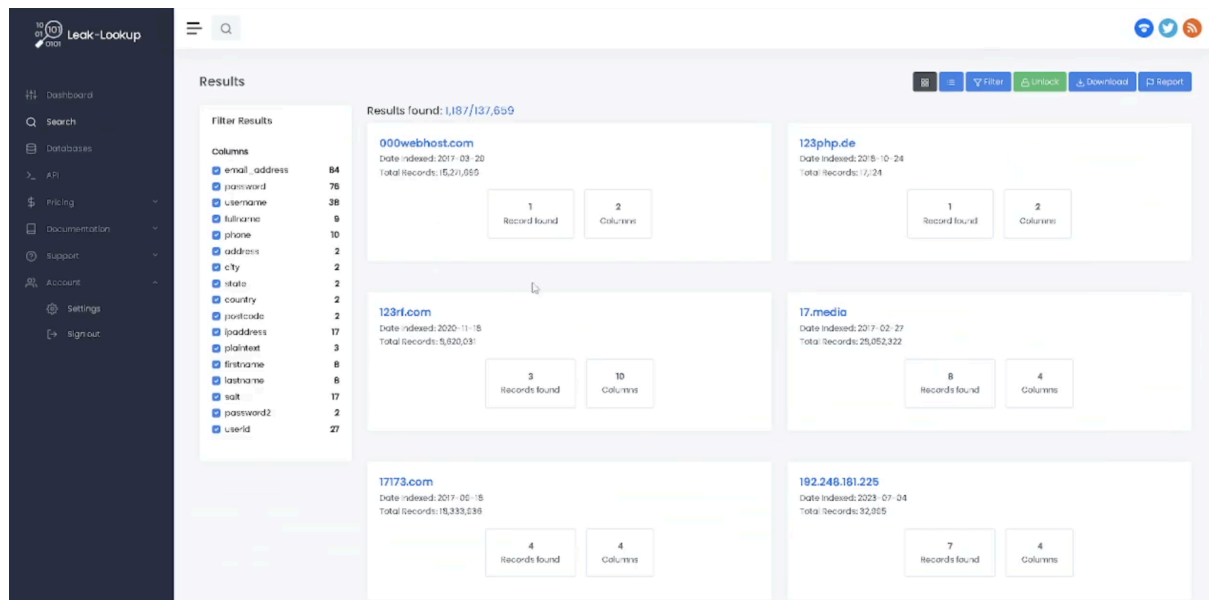
Podemos usar también Leak-Lookup. En este caso voy a hacer uso de las herramientas que son gratuitas, hay que hacerse cuenta de usuario pero independientemente es una cuenta gratuita de usuario con la que podemos hacer uso de la aplicación sin ningún problema.

En este caso vamos a replicar este mismo usuario, esta misma cuenta de email.

Nos dice que no ha encontrado nada.

Vamos a realizar por ejemplo otra búsqueda con otro email (test@test.com) a ver el tipo de información que muestra en cada uno de los casos.

Podemos realizar búsquedas no sólo a través de direcciones de email sino también de nombres de usuario.



Aquí por ejemplo nos muestra aplicaciones en las que ha tenido esas filtraciones y sería cuestión de analizarlas una por una, ver qué información muestra y nos dice el tipo de campos que se han encontrado en las bases de datos que han sufrido las filtraciones de esas bases de datos y que están asociadas o que tienen contenidos el email o el nombre de usuario que hemos introducido.

Por último vamos a usar en este caso la aplicación de leakcheck.io, veis que podemos elegir una gran variedad de opciones, tanto número de teléfono, el nombre de usuario, la dirección de email, etc.

Aquí por ejemplo nos muestra aquí parcialmente la contraseña que se ha filtrado en esa base de datos, nos dice el año en el que se produjo la filtración de la base de datos correspondiente y el número de veces que ha sido filtrado sin él.

Análisis de recursos expuestos en DVWA:

Continuamos con el tercer punto de este ejercicio y es el análisis de los recursos expuestos en DVWA.

Para ello en este caso vamos a hacer uso de la máquina Kali Linux como máquina atacante y por otra parte vamos a tener como máquina víctima metasploitable que tiene configurado el servicio DVWA pero también es perfectamente aplicable si tenemos ya DVWA en nuestra máquina. Sería cambiar la dirección IP por nuestra dirección IP de nuestro equipo local, comprobar que hay conexión entre ambos servicios y realizar las peticiones para realizar este análisis y enumeración de los servicios que tiene expuestos, más que servicios, de los recursos de los ficheros y de los ficheros que tiene habilitados y visibles y accesibles esta aplicación.

Y en este caso no he introducido ningún diccionario para realizar estas peticiones, he usado uno por defecto, pero se puede usar con el parámetro -w el diccionario que deseemos en cada caso.

```
dirsearch -u http://192.168.186.132/dvwa/
```

Según los diccionarios de Rockyou, Seclist, PayloadAlltheThings, etc, podemos especificar diccionarios según el tipo de información. Si por ejemplo sabemos que la aplicación utiliza un servidor o una tecnología, un CMS determinado, podemos usar diccionarios más específicos todavía para obtener resultados en estas búsquedas mucho más precisas.

El diccionario sería de menor tamaño y por lo tanto más rápido de obtener estos resultados, serían menos peticiones a la aplicación target que realizaríamos.

Por aquí ya estamos encontrando información como por ejemplo el fichero de CHANGELOG.txt.

Vamos a confirmarlo en el navegador, intentando entrar en el changelog.txt de la aplicación web dvwa en la ip de la máquina atacante:

```
192.168.186.132/dvwa/CHANGELOG.txt
```

Por defecto nos dirige al login, pero en este caso nos muestra la versión actual que tenemos en esta máquina de DVWA.

```
192.168.186.132/dvwa/CHANGELOG.txt
# Change Log v1.8.7 #
Re-designed the login page + made some other slight cosmetic changes. 06/06/2010 (ethicalhack3r)
Started PHPUnit implementation. 15/03/2010 (ethicalhack3r)
A few small cosmetic changes. 15/03/2010 (ethicalhack3r)
Improved the help information and look. 15/03/2010 (ethicalhack3r)
Fixed a few bugs thanks to Digininja. 15/03/2010 (ethicalhack3r)
Show logged in username. 05/02/2010 (Jason Jones)
Added new life on RandomStorm. 04/02/2010 (ethicalhack3r)
Added 'SQL Injection (Blind)'. 04/02/2010 (ethicalhack3r)
Added official documentation. 21/11/2009 (ethicalhack3r)
Implemented view all source functionality. 16/10/2009 (macuA, craig, ethicalhack3r)
# Change Log v1.8.6 #
Fixed a bug where the logo would not show on first time use. 03/09/2009 (ethicalhack3r)
Removed 'correct password' input box for lowered CSRF security. 02/09/2009 (ethicalhack3r)
Added more troubleshooting information. 02/09/2009 (ethicalhack3r)
Stored XSS high now sanitises output. 02/09/2009 (ethicalhack3r)
Fixed a 'bug' in XSS stored low which made it not vulnerable. 02/09/2009 (ethicalhack3r)
Rewritten command execution high to use a whitelist. 30/09/09 (ethicalhack3r)
Fixed a command execution vulnerability in exec high. 17/09/09 (ethicalhack3r)
Added some troubleshooting info for PHP 5.2.6 in readme.txt. 17/09/09 (ethicalhack3r)
Added the upload directory to the upload help. 17/09/09 (ethicalhack3r)
# Change Log v1.8.5 #
Made IE friendly as much as possible. 06/08/2009 (ethicalhack3r)
Removed the acunetix scan report. 30/08/2009 (ethicalhack3r)
Added 'Clear Log' button to PHPUnit parser. 27/08/2009 (ethicalhack3r)
Implemented PHPUnit log parser. 27/08/2009 (ethicalhack3r)
Implemented Stored XSS vulnerability. 27/08/2009 (ethicalhack3r)
Added intracss rule for localhost access only. 27/08/2009 (ethicalhack3r)
Added CSRF. 01/08/2009 (ethicalhack3r)
Implemented sessions/login. 01/08/2009 (ethicalhack3r)
Complete recode. (jamesr)
Complete redesign. (jamesr)
Relinked docs in session, minimising the risk of clash with other projects running on localhost. 01/08/2009 (jamesr)
Reintegrated PHPUnit v1.8. 01/08/2009 (jamesr)
```

Así con toda la información que nos expone al lanzar esta herramienta y teniendo que analizar posteriormente en las auditorías cada uno de estos ficheros para ver qué información podemos obtener, qué funcionalidades podemos acceder o qué formularios de login podríamos intentar autenticarnos, ver si tiene credenciales por defecto, pero esto ya son pasos posteriores en nuestras auditorías.

```
[09:21:26] Starting: dvwa/
[09:21:32] 403 - 304B - /dvwa/.ht_wsr.txt
[09:21:32] 403 - 307B - /dvwa/.htaccess.bak1
[09:21:32] 403 - 307B - /dvwa/.htaccess.save
[09:21:32] 403 - 307B - /dvwa/.htaccess.orig
[09:21:32] 403 - 307B - /dvwa/.htaccess_orig
[09:21:32] 403 - 308B - /dvwa/.htaccess_extra
[09:21:32] 403 - 305B - /dvwa/.htaccess_sc
[09:21:32] 403 - 306B - /dvwa/.htaccessOLD2
[09:21:32] 403 - 305B - /dvwa/.htaccessOLD
[09:21:32] 403 - 305B - /dvwa/.htaccessBAK
[09:21:32] 403 - 309B - /dvwa/.htaccess.sample
[09:21:32] 403 - 307B - /dvwa/.htpasswd_test
[09:21:32] 403 - 298B - /dvwa/.html
[09:21:32] 403 - 303B - /dvwa/.htpasswd
[09:21:32] 403 - 304B - /dvwa/.httr-oauth
[09:21:32] 403 - 297B - /dvwa/.htm
[09:22:22] 200 - 5KB - /dvwa/CHANGELOG
[09:22:22] 200 - 5KB - /dvwa/CHANGELOG.txt
[09:22:25] 301 - 329B - /dvwa/config → http://192.168.186.132/dvwa/config/
[09:22:26] 200 - 912B - /dvwa/config/
[09:22:26] 200 - 0B - /dvwa/config/config.inc
[09:22:28] 200 - 32KB - /dvwa/COPYING
[09:22:34] 301 - 327B - /dvwa/docs → http://192.168.186.132/dvwa/docs/
[09:22:34] 200 - 923B - /dvwa/docs/
[09:22:36] 200 - 1KB - /dvwa/dvwa/
[09:22:41] 200 - 1KB - /dvwa/favicon.ico
[09:23:01] 200 - 1KB - /dvwa/login
[09:23:01] 200 - 1KB - /dvwa/login.php
[09:23:02] 200 - 1KB - /dvwa/login/oauth/
[09:23:02] 200 - 1KB - /dvwa/login/cpanel.js
[09:23:02] 200 - 1KB - /dvwa/login/cpanel.html
[09:23:02] 200 - 1KB - /dvwa/login/cpanel.php
[09:23:02] 200 - 1KB - /dvwa/login/login
[09:23:02] 200 - 1KB - /dvwa/login/admin/admin.asp
[09:23:02] 200 - 1KB - /dvwa/login/super
[09:23:02] 200 - 1KB - /dvwa/login/cpanel.jsp
[09:23:02] 200 - 1KB - /dvwa/login/
[09:23:02] 200 - 1KB - /dvwa/login/administrator/
[09:23:02] 200 - 1KB - /dvwa/login/cpanel/
[09:23:02] 200 - 1KB - /dvwa/login/index
[09:23:02] 200 - 1KB - /dvwa/login/admin/
[09:23:02] 200 - 1KB - /dvwa/login/cpanel.aspx
[09:23:10] 200 - 148B - /dvwa/php.ini
[*****] 73% 8382/11460 59/s job:1/1 0/2000:0
```

En este caso nos limitamos a la obtención de información que vaya a estar expuesta dentro de la propia aplicación y ver qué información nos dan los recursos que vamos identificando.